

Secure Console Requirements

Introduction

This document specifies Meta's requirements for secure authentication, authorization, and accounting (AAA) mechanisms on its console servers. Implementations of these requirements must be robust, with minimal dependencies, to ensure high availability even during disaster recovery scenarios.

Background

Console servers are critical infrastructure that provide out-of-band (OOB) recovery access to network devices. We require controls for authentication at the console layer rather than rely on the auth enabled on end devices, which can have unpredictable results.

To address these security requirements, we specify a solution that implements SSH certificate-based authentication for console server access, along with standard password and SSH key-based authentication methods.

Requirement

The requirements of the Console Security solution are:

- Authenticate users prior to allowing access to the console ports.
- Be able to manage the current session
 - List all sessions on the device
 - List current session associated with a console port
 - Ability to terminate existing console sessions
- Provide telemetry capabilities for monitoring purposes
- Have API, OMCI support where applicable

Secure Authentication Details

SSH Certificate-Based Authentication

Meta is exploring SSH Certificate based authentication for hardening the security of access to the console ports. A solution that utilizes SSH certificates for authenticating users accessing console servers. This ensures secure access without the need for long-term credential storage on user devices.

Client Certificate

- User generates public/private key on client machine
- User requests internal mechanism for a client certificate - containing user's public key, signed with the SSH CA private key
- The user presents the client certificate to the console server which verifies the signature on the client certificate using the trusted SSH CA public key.

Host Certificate

- User's client machine initiates an SSH console connection via an intermediary internal mechanism
- The console server responds with the SSH Host Certificate which is issued by the SSH CA containing the console server's public key/host key, hostname.
- Client validates the signature on the Host certificate using the trusted SSH CA public key

Certificate Requirements

- The console servers should be able to securely manage SSH host keys, which will be signed by a Certificate Authority (CA) for hosts.
- Certificates can be short-lived (ex 5 minutes) to enhance security and eliminate the need for a Key Revocation List (KRL)
- Certificates can also be long-lived for general administrative and telemetry purposes
- The system should support certificates with specific principals identifying user roles
- SSH Host and Client certificates support
 - Able to validate that client certificate is issued by a trusted CA
 - Validate that the client certificate is not expired
- SSH host certificates will be signed by a trusted SSH CA and distributed to the console server

Certificate Format

The certificate will contain various pieces to identify associated entities. Some of which are:

- **Key-ID:** An opaque ID used for traceability
 - Key-ID must appear in all log messages related to the session
- **Serial Number:** A long sequence number
 - Serial Number must appear in all log messages related to the session
- **Principal:** Corresponds to a local user account or role.
 - *Example:* usernamebot-10
 - Must correspond to a locally-defined user account

User Accounts and Authentication

- Role-Based (RBAC) integration
- Should support creation of up to 128 accounts, with port-specific user matrices.
 - Each port may have one or more authorized user accounts
 - This user account can have read-only or read-write access level
- For certificate-based authentication:
 - The asserted username in the SSH connection request shall be discarded, as it cannot be securely authenticated against the certificate
 - Instead, the Principal present in the certificate shall be used to identify a locally-defined user account to use for the session
 - Permissions from this locally-defined account shall be used for the session
 - If the Principal in the certificate does not match any local user account, then authentication should fail
 - The validity start- and end-times from the certificate must be honored, if present in the certificate.
 - Sessions started during the validity period may continue to persist past the end of the certificate end-time.
- Multiple users can connect simultaneously to the same port
- All user accounts can be accessed using Certificate-based authentication. Additionally, each user account may optionally specify a password, key, or both, as additional authentication mechanisms for that account.
- Should be able to configure the number of failed re-tries and a specific lock out time for each re-try fail threshold.
- Should be able to configure disconnection of console session after a configurable inactivity interval
- These accounts should be configurable over OMCI

Functionality

- The solution should not depend on external authentication services like TACACS or RADIUS
- OpenSSH compliant solution, with 9.0+ support

Telemetry Delivery

Telemetry Delivery Mechanism

- The telemetry delivery mechanism on the console server shall utilize an in-band message mechanism to broadcast log messages to connected clients.
- The console server shall transmit log messages to connected clients using the same SSH port used for secure shell access, ensuring all clients sharing the same port receive identical information.
- Upon client disconnection, the console server shall terminate the log message connection, ceasing log message transmission until a new connection is established.
- The Key-ID, Serial number, and Principal from the certificate (if cert-based authentication is in-use) shall appear in all log messages related to the session, otherwise, the local user-ID shall instead appear.

Log Message Format

<CR><LF>#####<Port Details>: <Local Username>: <Timestamp> <Log Message>#####<CR><LF>

- Separate all fields with delimiters.
- Add specific delimiters for the Log Messages to clearly capture the start and end of a log message.

Telemetry Data

- Data available to consume as log messages.
 - User successfully authenticates
 - User fails to authenticate
 - User logs off or disconnects
 - Multiple users share same console session
 - Existing user's session is terminated

Manageability

- Configuration of all serial port parameters over OMCI
- Configuration of user list, credentials, and access table over OMCI
- Mechanisms to manage current sessions - list all sessions, view details of an individual session via OMCI
- Ability to terminate a session via OMCI
- Device must not expose CLI and API access, outside of OMCI mechanisms

OMCI Support

In addition to the general requirements of the SSH Certificate Based Authentication described in this document, OMCI support is necessary to support any Passive Optical Network infrastructure. All the general requirements which are considered primary regardless of PON or non-PON devices, apply here as well.

Acronyms:

OMCI - Optical Network Unit Management and Control Interface

ONU - Optical Network Unit

OLT - Optical Line Terminal

OMCI Protocol Requirements and Support

- Provide mechanism to configure ONT/ONU devices to use SSH Certificate Based authentication for console access
- PON devices should be able to have their SSH Host Keys signed by a Trusted SSH CA
- All the above configuration is done over OMCI and the console server should not listen on TCP Port 22 for this purpose.
- Console servers should be capable of managing current sessions, including listing active sessions and terminating them as needed. This functionality should be potentially manageable over OMCI.

Key Based Authentication

- The product or solution must support SSH key-based authentication, allowing users to authenticate using public/private key pairs.
- OMCI shall be used to manage these keys - whether adding, removing or updating them.

Password Based Authentication

- The product or solution must support password-based authentication, allowing users to authenticate using a username and password.
- OMCI shall be used to configure passwords for user accounts.